IT Focus data management, confidentiality. Operational Technology (OT) **Focus**: physical processes, availability, safety. Stricter uptime/deterministic requirements (real-time operations). Involve critical sys with severe physical consequences. **Challenge**: skill gaps + miscommunication IT/OT **CS Threats**: Malware, Ransomware, Advanced Persistent Threats (stealthy/continuous hacking), Insider Threat. **How to secure**: ntw segmentation (Separation of OT and IT), limit threat lateral movement, reduce risk unauthorized access), defense-in Depth strat (FW, IDS, encryption), access control, secure communication. Industrial Control System (ICS) Inf sys to control industrial processes.Includes SCADA. **Security Challenge**: Legacy protocol/sys => isolation/segmentation, limited visibility/patch management => enhance visibility, convergence IT/OT => securing external connection, supply chain risks/human error => access control and containing incident spread. Distributed Control System (DCS) ICS architecture where control is distributed betweeen entities Supervisory Control And Data Acquisition (SCADA) control and gather/process data from control geographically dispersed assets. Programmable Logic Controller (PLC) Programmable industrial computer that executes user-defined logic for I/O control, timing, counting, PID regulation, communication. Remote Terminal Unit (RTU) Computer with radio interfacing for remote sites without wired comms, to communicate with field equipment. Intelligent Electronic Device Microprocessor-based controller for power equipment (breakers, transformers, capacitors), integrates sensing/control/communication on device itself. Function Block Programming Graphical PLC programming language, links input/output variables through connected function blocks. Legacy OT lvl 0/1 devices: long lifecycle (10-20+ yrs), ruggedized/fanless/low-power, harsh conditions, strict SLA. Hard to patch/update => vulnerability accumulation. Risk Effect of uncertainty on objective. **Management**: Must be repeatable, scalable and transferable. Identify risk => compare to organization accepted risk threshold => avoid/transfer/mitigate,accept. Purdue Model (PERA) outlines interaction IT/OT. Enable better comm. IT/OT. Aims to reduce risk of threats. **lvl0**: instrument to sensing or acting on physical process (sensors, pumps, valves). **lvl1**: intelligent device to sense/monitor/control physical process (PLC, SIS, RTU). **lvl2**: Control sys to supervise/monitor physical process (HMI, SCADA). **lvl3**: operation sys to manage/control production flow (AD, File servers, Historians). **DMZ**: buffer btwn ICS/external ntw (Proxy, Mail, Replica). **lvl4**: enterprise ntw (data exchange, business-to-business, business-to-client). Governance Hierarchy External/internal influence => Policy (high lvl declaration = why) => Control Objective (objective of policy) => Standard (what to do to apply policy, mandatory) => Guideline (recommended way to meet standard, optionnal) => Control (implementation of standard) => Procedure (how to implement control). Risks/Threats justify Controls; Metrics measure Control effectiveness. Standardization **Goals** Maximize business benefits, institutionalize best practices in standards, be compliant (contract obligations, laws, regulation). Benefits: ensure fulfillment of necessary quality, preferred access to market, defines obligations, give guarantees. Standard vs Certification **Standard**: document describing best way of doing something (IEC, NIST, IEE, ISO). **Certification**: written assurance by an independent body that specific requirements (a standard) are met. Critical Infrastructure Not the same btwn USA/UE/CH. Energy (gas/power/oil supply), Finances, Inf&Communication (media, postal, telecom), Public Administration (government, justice, reasearch), Pulic Health (hospital, laboratory), Public Safety (army, ermegency services), Transport (air, rail, road), Food and Water, Waste disposal. Impact of regulations on OT **Obligations**: Policies on risk analysis and inf sys security, Incident handling, Business continuity (backup management/disaster recovery/crisis management), Supply chain security, Security in ntw and inf sys (acquisition/development/maintenance/vulnerability handling and disclosure), Policies and procedures to assess effectiveness of cs risk-management measures, Basic hygiene practices and cs training, Policies and procedures regarding use of cryptography, Human resources security, access control policy, asset management, use of MFA and secured emergency communications, coordinated vulnerability disclosure policy. **Impact**: fines up to 2% global revenue. CH: Criminal Code (data theft/unauthorized access/data damage/computer fraud). Role of communication systems **Goals**: Facilitate inf flow to improve operations effeciency. Enhance better decision making with real-time data. Promote Operational Continuity with reliable communication sys. **Requirement**: Determinism/Real-Time, Scalability, Reliability, Availability, Latency, Time Sync., Open standards/Interoperability, Security. **Why real-time**: needed for timely/accurate data processing, control actions, precision/rapid response. **Quality Of Service (QoS)**: priorize netw traffic (critical data first), minimize delay, maintain operational efficiency and productivity. **RTOS**: combined with comm ensure efficient task management, rsc allocation, real-time perf. **WAN Requirement**: deterministic end-to-end perf (no best effort), guaranteed QoS/delay/jitter, precision time&clock, encrypted packet, fast path protection switching. **Encryption/Network Segmentation**: need for data protection against breach/unauthorized access. Access limitation to reduce risk and enhance security posture. **Use of Secure Protocols**: to ensure privacy/integrity, prevent eavesdropping. **Heterogeneity of OT Systems**: variety of device with unique specs and fct, protocols => Interoperability Challenge. **Open Standard**: ensure interoperability, facilitate communication, enhance data exchange. Communication Protocol Classification External (protocol relies on external security measure ?), Msg integrity ? Msg confidentiality ? Secure Authentication and Authorization ? OT Wired Communication Favored for their high-speed/stable capabilities (crucial for real-time data). Ethernet: non-time-critical comm btwn lvl1 and lvl2. FieldBus: wired protocol to link lvl0 and lvl1. time crititical/cost requirement **MODBUS**: client-server/master-slave arch with limited computing rsc. simplicity, interoperability, cost-effectivness, flexibility, wide adaption. limited bandwidth, no built-in security/redundancy, limited error handling, limited addr space, no support complex data, polling overhead, no safety/real-time **EtherCAT**: real-time ethernet, topology agnostic, support for 2^16 devices, sync with distributed clocks. real-time comm, cost-efficiency, scalability, flexible topology, high reliability. complex ntw design, device compatibility, integration/debugging OT Wireless Communication: Flexibility and Mobility (connection without physical constraint). Need careful implementation to mitigate interference/risks. **Critical factors**: Limited energy capacity, HW constraints, Dynamic ntw, Node deployment, Fault tolerance, Latency, Data aggregation, Scalability. **Zigbee**: mesh WPAN. Roles: Coordinator(ZC) (first started node, form ntw, allow other node to join ntw, unique), Router(ZR) (routing, multiple), End device(ZED) (send/receive only, can be sleepy). low power, low cost, scalable (up to 65k devices), 128-bit sym key. low data rate, short range.**WirelessHART**: bi-directional industrial field communication btwn host sys and field device. Provides 2 simultaneous channels (analogue, digital). Roles: Field device, Gateway (bridge to host/backbone), Network Manager (schedules comm, routes, monitors health). low power, scalable, time sync, TDMA, redundant transmission, frequency hopping. mid-range only. **Security**: end-to-end encryption (128-bit AES), unique key/message, rotating join keys, common ntw key for broadcast, join key = device authentication. **Others**: 5G, Wi-Fi. SyncE derives clock sync from physical-layer signal edges. PTP GPS-based grandmaster sends timestamped packets to sync slave clocks. Time Sensitive Network (TSN) Deterministic data transmission. Suitable for industrial automation application. Time sync btwn devices => ensure data transmission over defined time parameters. Allow allocation/priorization of ntw bandwidth. Enhance realiability => minimize packet loss/latency. Interoperability with existing Ethernet standards. **Guard Band**: blocks new low-priority frames just before a critical time slot, so no frame overruns into it. $\text{G\_size}\ [\mu s] = \frac{\text{max\_frame\_size [bytes]}}{\text{link\_rate [Mb/s]}}$. Air-Gapped No physical link OT/IT (extreme segmentation). threat mitigation, compliance, data integrity. infra cost, insider threat still possible, hard to update/maintain. Multi Protocol Label Switching (MPLS) Faster than per-packet IP routing lookup. Data transport protocol based on labels, layer 2.5 (btwn L2&3 OSI). Link ip addr to label (FEC). Allow various app (VPN, traffic aggregation, QoS). Use Label Swapping Table **LSP**: path through ntw = sequence of labels, each LSR swaps label, "tunnel" w/o inspecting inner header. **LSR**: core router, high-speed label swapping. **LER**: ntw edge, push/pop label (IP<=>MPLS), assign FEC. **Flow**: LER push label => LSR swap => ... => LSR swap => LER pop label (back to ip). Intrusion Detection/Protection System (IDS/IPS) monitor network to allow real-time suspicious activity detection => immediat response. **Network-based**: monitor traffic on ntw segment. **Host-based**: monitor local logs/files/processes/traffic on a single host. **Hybrid**: combine both ntw+host view. **Behavioural**: detect deviation from learned normal behavior (anomaly-based). Warning: acting on identified threat can impact production. Zero Trust All data/computing services = rsc. No implicit trust based on ntw location, secure every comm. Access granted per-session, via dynamic policy (behavioral/environmental attributes). Authentication/authorization strictly enforced, re-checked dynamically. Continuously monitor asset/ntw integrity to improve security posture. Open Platform Communications Unified Architecture (OPC UA) standard for industry 4.0 convergence (cyber, physic, human, logistic, sell, etc.). Standardized access to all components, Manufacturer-independent data exchange, platform independent. Rich/extensible info model (complex types). state of art native security (vs Modbus: no native security). **Modes**: Client-Server, Publisher-Subscriber (PubSub). IEC 61850 standard for defining devices within substation automation systems and how their interactions. **Platform for**: comm, protection, control, automation, measurements, recording, monitoring. **Features**: self description (interrogation), fast peer-to-peer (tripping/blocking/interlocking), reduce hard-wired connections, reporting. **Standardizes**: design, language, services, protocol, config, substation/device info, naming convention, fault records, conformance tests. **Protocols**: MMS, GOOSE, Sampled Values (SV). Product LifeCycle Management (PLM): Ensure that every involved person has access to inf about all process. **1) Idea**: New ideas based on market research. Creative/Structured phase to determine if product can succeed => Understanding client needs and market trends. **2) Design**: Detail specifications, plans and prototypes. Ensure its functional and feasable. Need versionning => Make the product appealing **3) Manufacturing**: Design to product. Include sourcing materials, setting up production lines, quality control. Design data is integrated to manufacturing process to keep errors low and improve efficiency => Ensure data meets brand promise and quality standards **4) Service&Maintenance**: Distribution, customer services, maintenance. track product perf and customer feedbacks to improve product => Ensure customer satisfaction and enable longer product lifespan. **5) Disposal**: Safe/responsible disposal/recycling. According to regulations and sustainability practices. Product Cybersecurity Lifecycle **Secure Product Development**: Secure Product => Security Planning&Classification => Threat Modeling&Risk Assessment => Security Requirements => Security Architecture&Design =>

Secure Sourcing => Secure Implementation => Security Testing => Security Documentation => Security Certifications => DevSecOps => back to Secure Product. **Post Launch Product Security**: Secure Product => Secure Deployment&Operation => Security Maintenance/Patching => Configuration Management => Vulnerability Management => Information Sharing => Customer Security Collaboration => Security Monitoring => Threat Intelligence => Incident&Crisis Handling => Secure End of Life => back to Secure Product. **Foundations**: Cyber Security Management System(s); Development&Production Security/Security Risk Management; Organization Culture Awareness&Training/Supply Chain Security. Activities within a Company **Development**: Requirements (Requirements Mgmt) => Design (Architecture/Design Reviews, Defense in Depth, Product Composition definition, Procurement) => Implementation (Code Analysis/Reviews, Secure Coding Standards, Hardening, Procurement) => Testing (Verification, Automated Security Testing, Penetration Testing, OSS Identification) => Launch (Release Clearance, Code Signing, Customer Security Doc.) => **Manufacturing** => Production (Key Provisioning, Logistics) => **Operation** => Issue management (Supported: Update/Vulnerability Mgmt; Issue Mgmt: Incident Mgmt; Obsolete: Decommissioning). **Continuous (full lifecycle)**: Threat Modeling; Secure Environment&Infra/Information Security/Human Risk Mgmt; Roles&Responsibilities/Training/Sharing/Evangelizing; Risk Mgmt/Governance Definition/Metrics. Software Bill Of Material: **Why**: trust in digital infra should be proportional to its transparency, lack of it increases cyber risk + dev/procurement/maintenance cost. **Minimum content**: organization/person that created artifact, used tool to generate the SBOM, timestamp SBOM generation, component name, component version, UUID, relationship with other component. **More requirements**: Frequency (update on any change), Depth (all direct+indirect dependencies), Known Unknowns (state if info missing/why), Distribution&Delivery (machine+human readable, accessible to customer), Access Control, Accommodation of Mistakes (standard still evolving). Secure Boot Hardware-backed root of trust: each boot stage verifies signature/crypto key of next stage before executing (Boot ROM => U-Boot SPL => U-Boot => Linux Kernel => Application). **Challenges**: vendor-specific (NDA to access docs), key management (on/off device), key rotation, OSS licences (GPL), 3rd-party app integration. Supply Chain Risk Management Applies to IT+OT+IoT. Manages cyberrisk from ICT/OT products, services, suppliers, system integrators, service providers. **Process**: Threats (adversarial: malware/espionage/disruption; non-adversarial: disaster/poor quality/regulatory) x Vulnerabilities (external: supplier interdependencies; internal: unpatched sys, lack of awareness) => Likelihood => Impact (degree of harm) => Risk.